

DSGVO · ARTIKEL 28 ABS. 3

Auftragsverarbeitungsvertrag

Vereinbarung zwischen dem Vermieter (Verantwortlicher) und MyImmo (Auftragsverarbeiter) über die Verarbeitung personenbezogener Daten in der MyImmo-Anwendung.

Auftragsverarbeiter: Jonas Scharp (MyImmo) · Ludwig-Jahn-Straße 42 · 23611 Bad Schwartau ·
info@myimmoapp.de

Verantwortlicher: die Nutzerin / der Nutzer des jeweiligen MyImmo-Kontos (Vermieter)

Stand: 24. Juli 2026

Entwurf zur anwaltlichen Prüfung. Dieses Dokument dient der rechtlichen Durchsicht und ist noch nicht final freigegeben. Keine Rechtsberatung.

Auftragsverarbeitungsvertrag (AVV)

Vereinbarung nach Art. 28 Abs. 3 DSGVO · Stand 24. Juli 2026

1. Parteien, Gegenstand und Dauer

Verantwortlicher: die Nutzerin / der Nutzer des jeweiligen MyImmo-Kontos (Vermieter).

Auftragsverarbeiter: Jonas Scharp (MyImmo), Ludwig-Jahn-Straße 42, 23611 Bad Schwartau („Betreiber“).

Gegenstand ist die Bereitstellung der Web-Anwendung MyImmo zur Immobilien- und Mietverwaltung, in der der Verantwortliche personenbezogene Daten Dritter (insbesondere seiner Mieter und Mietinteressenten) speichert und verarbeitet. Die Vereinbarung gilt für die Dauer des Nutzungsverhältnisses und endet mit der Löschung des Kontos.

Nicht Gegenstand dieser Fassung: Die treuhänderische Verwaltung fremder Immobilienbestände durch gewerbliche Hausverwaltungen (Mehrmandanten-Verwaltung) wird – vor ihrer produktiven Nutzung – durch eine gesonderte Ergänzung dieses Vertrags geregelt.

2. Art und Zweck der Verarbeitung

Hosting, Speicherung, Anzeige, Auswertung und Ausgabe (z. B. Abrechnungen, Briefe, Exporte) der vom Verantwortlichen erfassten Daten. Hinzu kommen — jeweils auf Veranlassung des Verantwortlichen — Selbstbedienungs-Funktionen für die von ihm eingeladenen Mieter (Meldung von Zählerständen mit Foto-Beleg, Schadens- und sonstige Anliegen mit Foto-/Dokumentanhängen, Terminabstimmung sowie die Beantwortung von Anfragen des Verantwortlichen), die Erfassung und Auswertung von Mietbewerbungen (Selbstauskünfte von Mietinteressenten), die Abwicklung von Aufträgen mit vom Verantwortlichen beauftragten Service-Partnern (Handwerkern, Hausmeistern) – einschließlich der hierfür erforderlichen Weitergabe von Objekt- und Mieterkontaktdaten zur Termin- und Leistungsabstimmung –, KI-gestützte Dokumentauswertung sowie zeitlich begrenzte Freigaben an vom Verantwortlichen benannte Empfänger (z. B. Banken). Eine Verarbeitung zu eigenen Zwecken des Betreibers findet nicht statt.

3. Art der Daten und Kategorien betroffener Personen

Datenarten:

- Stammdaten (Name, Anschrift, Kontaktdaten);
- Vertragsdaten des Mietverhältnisses (Mietbeginn/-ende, Miete, Kaution, Einheit);
- Abrechnungs- und Zahlungsdaten einschließlich Bankverbindung (letztere anwendungsseitig verschlüsselt);
- Verbrauchsdaten, einschließlich der vom Mieter selbst gemeldeten Zählerstände nebst Foto-Belegen;
- Anliegen- und Kommunikationsdaten: vom Mieter gemeldete Schäden, Fragen und Dokumentanfragen mit Freitext und Foto-/PDF-Anhängen; Anfragen des Verantwortlichen und Antworten des Mieters; Daten zur Terminkoordination;
- Dokumente, Belege und Übergabeprotokolle;
- Bewerbungsdaten von Mietinteressenten: selbst angegebene Angaben zu Beruf, Arbeitgeber, Netto-Einkommen, Bonität/SCHUFA, Haushaltsgröße, Haustieren/Rauchen, eine Freitext-Nachricht sowie eine elektronische Unterschrift;
- Auftrags- und Dienstleisterdaten: Aufträge an Service-Partner (Titel, Beschreibung, Objekt- und Vermietername, Termin, Betrag, Lohnanteil nach § 35a EStG), zugehörige Rechnungen sowie Kontaktdaten beauftragter Handwerks- und Dienstleistungsbetriebe;
- Notizen des Verantwortlichen.

Besondere Kategorien personenbezogener Daten (Art. 9 DSGVO) sind nicht Gegenstand der Verarbeitung; der Verantwortliche trägt dafür Sorge, keine solchen Daten in Freitext- oder Upload-Feldern einzugeben.

Betroffene Personen:

- Mieter und ehemalige Mieter des Verantwortlichen, die die App teilweise selbst nutzen (eigener, per Einladung erstellter Zugang);
- Mietinteressenten und Bewerber;
- weitere im Haushalt lebende oder im Mietverhältnis auftretende Personen (z. B. Mitbewohner, Bürgen);
- vom Verantwortlichen beauftragte Service-Partner (Handwerker, Hausmeister) und deren Ansprechpartner;
- Ansprechpartner von Banken bei Freigabe-Rückmeldungen.

4. Weisungsbindung (Art. 28 Abs. 3 lit. a)

Der Betreiber verarbeitet die Daten ausschließlich auf dokumentierte Weisung des Verantwortlichen; Weisungen werden über die Funktionen der App erteilt (Anlegen, Ändern, Freigeben, Löschen). Auch Eingaben, die vom Verantwortlichen eingeladene Mieter oder Mietinteressenten über die von ihm freigeschalteten Funktionen selbst vornehmen (z. B. Zählerstände, Anliegen, Bewerbungen), gelten als im Auftrag und auf Veranlassung des Verantwortlichen erfolgt. Hält der Betreiber eine Weisung für rechtswidrig, informiert er den Verantwortlichen unverzüglich. Eine Verarbeitung nach dem Recht der Union oder eines Mitgliedstaats bleibt vorbehalten; in diesem Fall wird der Verantwortliche vorab informiert, soweit rechtlich zulässig.

5. Vertraulichkeit (lit. b)

Zum Zugriff befugte Personen sind zur Vertraulichkeit verpflichtet. Der Betreiber greift auf Inhaltsdaten nur zu, soweit dies für Betrieb, Fehlerbehebung oder auf Wunsch des Verantwortlichen erforderlich ist.

6. Sicherheit der Verarbeitung (lit. c, Art. 32)

Der Betreiber trifft die in der Anlage TOM (unten) beschriebenen technischen und organisatorischen Maßnahmen und entwickelt sie entsprechend dem Stand der Technik fort.

7. Subauftragsverarbeiter (lit. d)

Der Verantwortliche erteilt die allgemeine Genehmigung zum Einsatz folgender Subauftragsverarbeiter:

- **Supabase Inc.** — Datenbank, Authentifizierung, Datei-Speicher; Datenhaltung Frankfurt (AWS eu-central-1); DPA mit EU-Standardvertragsklauseln.
- **Vercel Inc. (USA)** — Hosting/Auslieferung; DPA mit EU-Standardvertragsklauseln.
- **Anthropic PBC (USA)** — KI-Auswertung, nur bei aktiver Nutzung durch den Verantwortlichen; DPA mit EU-Standardvertragsklauseln; kein Modell-Training mit API-Daten.
- **Google Ireland Ltd.** — nur „Login mit Google“ und Schriftarten-Auslieferung.
- **Enable Banking Oy (Finnland/EU)** — Kontoinformationsdienst (Open Banking, nur bei aktiver Konto-Anbindung durch den Verantwortlichen); lizenziertes AISP unter Aufsicht der FIN-FSA; Verarbeitung in der EU.

Über beabsichtigte Änderungen (Hinzufügen/Ersetzen) informiert der Betreiber vorab in der App oder per E-Mail; der Verantwortliche kann innerhalb von 14 Tagen aus wichtigem Grund widersprechen. Bei Widerspruch steht beiden Parteien die Kündigung des Nutzungsverhältnisses offen. Der Betreiber verpflichtet Subauftragsverarbeiter auf mindestens gleichwertige Datenschutzpflichten und haftet für sie wie für eigenes Handeln. Übermittlungen in Drittländer erfolgen nur mit Garantien nach Kap. V DSGVO (Standardvertragsklauseln bzw. Angemessenheitsbeschluss).

Von Subauftragsverarbeitern zu unterscheiden sind Empfänger, an die der Verantwortliche über die App bewusst Daten weitergibt – etwa Banken bei Dokumentfreigaben oder von ihm beauftragte Service-Partner (Handwerker, Hausmeister) zur Auftrags- und Terminabwicklung. Diese Weitergabe erfolgt ausschließlich auf Veranlassung des Verantwortlichen; die Empfänger verarbeiten die Daten für ihre eigenen Zwecke in eigener datenschutzrechtlicher Verantwortung.

8. Unterstützung bei Betroffenenrechten (lit. e)

Der Betreiber unterstützt den Verantwortlichen mit geeigneten Mitteln bei der Beantwortung von Anträgen betroffener Personen (Art. 12–23 DSGVO) — insbesondere durch die Auskunfts-, Export-, Berichtigungs- und Löschfunktionen der App. Anträge, die beim Betreiber eingehen, leitet er unverzüglich an den Verantwortlichen weiter.

9. Meldepflichten und weitere Unterstützung (lit. f)

Der Betreiber meldet dem Verantwortlichen Verletzungen des Schutzes personenbezogener Daten unverzüglich nach Bekanntwerden mit den Informationen nach Art. 33 Abs. 3 DSGVO und unterstützt ihn bei seinen Pflichten aus Art. 32–36 DSGVO (Sicherheit, Meldungen, ggf. Datenschutz-Folgenabschätzung) unter Berücksichtigung der verfügbaren Informationen.

10. Löschung und Rückgabe (lit. g)

Nach Ende des Nutzungsverhältnisses — insbesondere bei Kontolöschung durch den Verantwortlichen — werden sämtliche personenbezogenen Daten einschließlich der Dateien im Datei-Speicher unwiderruflich gelöscht, soweit keine gesetzliche Aufbewahrungspflicht des Betreibers entgegensteht. Der Verantwortliche kann seine Daten zuvor über die Export-Funktionen der App sichern. Restkopien in technischen Backups werden turnusmäßig überschrieben.

11. Nachweise und Kontrollen (lit. h)

Der Betreiber stellt dem Verantwortlichen alle zum Nachweis der Einhaltung dieses Vertrags erforderlichen Informationen zur Verfügung (insbesondere diese Vereinbarung, die Anlage TOM und die Zertifizierungen/DPAs der Subauftragsverarbeiter) und ermöglicht angemessene Überprüfungen. Kontrollen erfolgen in der Regel durch Auskünfte und Vorlage geeigneter Nachweise; Vor-Ort-Kontrollen nur bei konkretem Anlass und nach Ankündigung.

12. Schlussbestimmungen

Es gilt deutsches Recht. Die Haftung richtet sich nach Art. 82 DSGVO und den gesetzlichen Regeln. Sollten einzelne Bestimmungen unwirksam sein, bleibt der Vertrag im Übrigen wirksam. Bei Widersprüchen zu den allgemeinen Nutzungsbedingungen geht dieser AVV in Datenschutzfragen vor.

Anlage: Technische und organisatorische Maßnahmen (TOM)

- **Zugangs-/Zugriffskontrolle:** Anmeldung mit E-Mail/Passwort (bcrypt-Hash) oder Google-OAuth; strikte Mandantentrennung je Konto auf Datenbankebene (Row Level Security); private Datei-Speicher mit Zugriff nur über kurzlebige signierte Links bzw. eigentümergebundene Richtlinien.
- **Übertragungskontrolle:** ausschließlich TLS-verschlüsselte Verbindungen; Content-Security-Policy und Sicherheits-Header.
- **Verschlüsselung:** Speicherung bei Anbietern mit Verschlüsselung „at rest“; zusätzlich anwendungsseitige AES-256-GCM-Verschlüsselung von Bankverbindungsdaten mit Schlüssel außerhalb der Datenbank.
- **Verfügbarkeitskontrolle:** Betrieb bei professionellen Cloud-Anbietern mit redundanter Infrastruktur und turnusmäßigen Backups.

- **Trennungsgebot:** Row Level Security stellt sicher, dass jedes Konto ausschließlich eigene Datensätze lesen und schreiben kann; Bank-Freigaben liefern nur explizit ausgewählte Dokumente über ablaufende, widerrufbare Token aus.
- **Eingabekontrolle:** Änderungen erfolgen kontogebunden über authentifizierte Sitzungen; destruktive Aktionen erfordern Bestätigung. Selbstbedienungs-Eingaben von Mietern und Mietinteressenten (Zählerstände, Anliegen, Bewerbungen, Datei-Uploads) sind dem einladenden Verantwortlichen zugeordnet und nur diesem zugänglich.
- **Organisatorisches:** Zugriff auf Produktionssysteme nur durch den Betreiber; Geheimnisse (API-Schlüssel, Verschlüsselungsschlüssel) werden außerhalb des Quellcodes in der Hosting-Umgebung verwaltet.

Unterzeichnung

In der App wird dieser Vertrag mit der Registrierung bzw. der weiteren Nutzung wirksam. Für die schriftliche Vorlage:

Verantwortlicher (Vermieter)

Auftragsverarbeiter (Mylmmo)

Ort, Datum

Ort, Datum

Name / Unterschrift

Jonas Scharp